
Author

author:

name: Иваненко Дмитрий Кириллович, Волобуев Иван Андреевич, Зеленко
Ирина Юрьевна, Замула Егор Сергеевич, Шмавонян Диана Арамов affiliation:
- name: Российский университет дружбы народов
country: Российская Федерация
postal-code: 117198
city: Москва
address: ул. Миклухо-Маклая, д. 6

Title

title: "Отчёт по лабораторной работе №1"

subtitle: "Группа Zetta"

license: "CC BY"

abstract: |

В данном отчёте представлены результаты выполнения лабораторной работы по теме РАССЛЕДОВАНИЕ ИНЦИДЕНТА С УТЕЧКОЙ КОНФИДЕНЦИАЛЬНОЙ ИНФОРМАЦИИ О МЕСТОПОЛОЖЕНИИ СОТРУДНИКОВ

Описаны использованные методы, полученные экспериментальные данные и их анализ.

Сделаны выводы о достижении поставленной цели.
keywords: [лабораторная работа, Markdown, Pandoc]

Введение

Накануне важных выборов произошел инцидент, связанный с утечкой конфиденциальной информации о передвижениях и активности ключевых политиков. Оппозиционная партия использовала уязвимость в протоколе SS7 для проведения атаки. Хакеры, работающие на оппозицию, получили информацию о местоположении и статусе высокопоставленных членов правящей партии.

Квалификация группы хакеров высокая. Хакеры используют специальное оборудование, атакуют специфические протоколы телекоммуникационной системы.

Актуальность

Актуальность обусловлена тем, что инцидент произошел накануне важных выборов, когда утечка данных о ключевых политиках способна напрямую повлиять на политическую ситуацию. Использование уязвимости протокола SS7 демонстрирует высокий уровень угрозы: атака затрагивает не приложения, а саму телекоммуникационную инфраструктуру, что делает её сложной для обнаружения и предотвращения. Высокая квалификация хакеров и применение специального оборудования свидетельствуют о целенаправленном характере атаки и требуют пересмотра подходов к защите телекоммуникационных систем.

Цель работы

Освоить методы обнаружения, анализа и устранения последствий компьютерных атак на примере инцидента с утечкой конфиденциальной информации о местоположении сотрудников через уязвимость Any Time Interrogation (ATI) в протоколе SS7. Получить практические навыки анализа сетевого трафика,

работы с журналами событий и настройки средств блокировки на межсетевом экране pfSense и с помощью iptables.

Задачи

Изучить теоретические основы протокола SS7, его архитектуру и уязвимость Any Time Interrogation (ATI).

Ознакомиться со сценарием атаки: сканирование сети, эксплуатация уязвимости, получение конфиденциальных данных абонентов (IMSI, HLR, IMEI, местоположение).

Обнаружить факт эксплуатации уязвимости средствами ОС Linux на машине Dragon OS:

проанализировать лог-файл maplog.log;

исследовать дампы трафика в /var/log с помощью Wireshark.

Проанализировать запросы и ответы ATI, выявить, какие данные были скомпрометированы.

Закрывать уязвимость двумя способами:

создать блокирующее правило на pfSense;

настроить специальные правила с помощью iptables.

Задokumentировать каждый шаг скриншотами и занести результаты в отчёт.

Объект и предмет исследования

Объект телекоммуникационная инфраструктура, эмулирующая работу протокола SS7 (машина Dragon OS), и процесс взаимодействия с ней внешнего нарушителя (Kali Linux). Предмет уязвимость Any Time Interrogation (ATI) в протоколе SS7, методы её обнаружения по журналам событий и сетевому трафику, а также способы блокировки нежелательного трафика на межсетевом экране и с помощью iptables.

Методы исследования

Анализ документации и источников по протоколу SS7 и уязвимости ATI.

Эмуляция атаки с использованием фреймворка SigPloit на машине Kali Linux.

Анализ журналов событий (maplog.log) средствами ОС Linux.

Анализ сетевого трафика с помощью утилиты Wireshark (фильтрация по протоколу GSM MAP, поиск запросов invoke anyTimeInterrogation).

Настройка межсетевого экрана pfSense для блокировки SCTP-трафика.

Настройка iptables для блокировки входящего трафика на порт 2906.

Схема выполнения работы

На рис. -@fig-flowchart представлена общая последовательность действий при выполнении работы.

```
::: {#fig-flowchart}

```{mermaid}
%%| fig-width: 100%
graph TD
 A@{ shape: circle, label: "Начало" } --> B[Выполнить действие]
 B --> C[Описать, что конкретно сделано]
 C --> D[Подтвердить скриншотом]
 D --> E[Занести в отчёт]
 E --> F[Поместить в git-репозиторий]
 F --> G[Сделать релиз git]
 G --> J@{ shape: dbl-circ, label: "Конец" }
...

```

Блок-схема выполнения лабораторной работы

:::

# Теоретическая часть

Протокол SS7 и его роль в телекоммуникациях

SS7 (Signaling System 7) – набор протоколов сигнализации, используемый в телефонных сетях для установления соединений, маршрутизации вызовов, управления услугами и обмена служебной информацией между элементами сети. Основные компоненты:

STP (Signaling Transfer Point) – транзитный пункт сигнализации;

HLR (Home Location Register) – реестр домашних абонентов;

VLR (Visitor Location Register) – реестр гостей абонентов;

MSC (Mobile Switching Center) – центр коммутации мобильной связи.

Уязвимость Any Time Interrogation (ATI)

ATI – процедура, позволяющая запрашивать информацию о местоположении и статусе абонента. При отсутствии должной проверки прав доступа нарушитель может отправить запрос ATI и получить:

IMSI (International Mobile Subscriber Identity) – международный идентификатор абонента;

IMEI (International Mobile Equipment Identity) – идентификатор оборудования;

MSISDN – номер абонента;

данные о местоположении (VLR, географические координаты);

информацию о статусе устройства.

Уязвимость затрагивает сети GSM и UMTS и может использоваться для слежки, подбора паролей и мошенничества.

#### Инструменты

SigPloit – фреймворк для тестирования безопасности телекоммуникационных сетей (SS7, GTP, Diameter, SIP).

Wireshark – анализатор трафика.

pfSense – межсетевой экран с веб-интерфейсом.

iptables – утилита управления правилами фильтрации пакетов в Linux.

Например, в табл. -@tbl-std-dir приведено краткое описание стандартных каталогов Unix.

Имя каталога	Описание каталога
``/``	Корневая директория, содержащая всю файловую систему
``/bin``	Основные системные утилиты, необходимые как в однопользовательском режиме, так и при обычной работе всем пользователям
``/etc``	Общесистемные конфигурационные файлы и файлы конфигурации установленных программ
``/home``	Содержит домашние директории пользователей, которые, в свою очередь, содержат персональные настройки и данные пользователя
``/media``	Точки монтирования для сменных носителей
``/root``	Домашняя директория пользователя ``root``
``/tmp``	Временные файлы
``/usr``	Вторичная иерархия для данных пользователя

: Описание некоторых каталогов файловой системы GNU Linux {#tbl-std-dir}

Более подробно про Unix см. в [ @tanenbaum\_book\_modern-os\_ru; @robbins\_book\_bash\_en; @zarrelli\_book\_mastering-bash\_en; @newham\_book\_learning-bash\_en ].

#### # Материалы и методы

Оборудование: виртуальные машины Kali Linux (внешний нарушитель) и Dragon OS (эмуляция SS7-сервера и жертвы).

Программное обеспечение: фреймворк SigPloit, Wireshark, pfSense, iptables, ОС Linux.

Исходные данные: сеть 195.239.174.0/24, открытый порт 2906, лог-файл /home/gh0/restcomm-jss7-7.0.1383/ss7/maplog.log, дамп трафика wireshark\_00001\_20240212052136.

Последовательность действий:

Сканирование сети и выявление открытого порта.  
Эксплуатация уязвимости ATI с помощью SigPloit.  
Обнаружение атаки по журналам и трафику.  
Анализ скомпрометированных данных.  
Блокировка трафика на pfSense и iptables.

# Выполнение лабораторной работы

Заккрытие уязвимости

Блокирующее правило на pfSense

Для создания блокирующего правила на pfSense:

перейдите в веб-интерфейс межсетевого экрана pfSense по адресу <https://10.10.1.254>;

перейдите во вкладку Firewall / Rules, нажмите Add;

в разделе Edit Firewall Rule, в выпадающем списке Action

выберите действие Block;

в выпадающем списке Protocol выберите SCTP;

в разделе Source выберите Single host or alias и введите

IP-адрес узла внешнего нарушителя;

в разделе Destination выберите Single host or alias и введите Telecom;

<https://github.com/iyzelenko/--Zetta/blob/main/ф4.png> (Рис.1 - Блокирующее правило на pfSense)

сохраните настройки правил межсетевого экрана, нажмите в нижней части страницы Save, в верхней части - Apply Changes.

<https://github.com/iyzelenko/--Zetta/blob/main/ф5.png> (Рис. 2 -Создание правила на pfSense)

Специальные настройки с помощью iptables

Для блокировки входящего и исходящего трафика по протоколу SCTP на данном порту с использованием iptables

зайдите в консоль, введите учетные данные пользователя;

<https://github.com/iyzelenko/--Zetta/blob/main/ф1.png> (Рис.3 -

Подключение к удаленному рабочему столу)

введите команду `sudo iptables -A INPUT -s 195.239.174.11`

`-p sctp --dport 2906 -j DROP` для запрета доступа нарушителя к серверу SS7.

<https://github.com/iyzelenko/--Zetta/blob/main/ф2.png> (Рис. 4 - Блокировка трафика для порта 2906 с помощью iptables)

<https://github.com/iyzelenko/--Zetta/blob/main/ф3.png> (Рис. 5 - Подтверждение действия команды)

# Результаты

В ходе работы выполнена настройка средств защиты SS7-сегмента от несанкционированного SCTP-трафика. В pfSense создано блокирующее правило

для запрета соединений по протоколу SCTP от внешнего нарушителя 195.239.174.11 к узлу Telecom/SS7. Также на защищаемом Linux-сервере с помощью iptables добавлено правило, блокирующее входящие SCTP-пакеты от указанного IP-адреса на порт 2906. Это предотвращает повторное использование обнаруженного пути атаки и повышает безопасность телекоммуникационной сети

# Обсуждение результатов

Полученные результаты согласуются с теоретическими ожиданиями: уязвимость АТІ позволяет внешнему нарушителю при наличии доступа к сигнальной сети SS7 получать конфиденциальные данные абонентов без их согласия. Обнаружение атаки возможно как на уровне журналов приложений (maplog.log), так и на уровне сетевого трафика (Wireshark), что подтверждает необходимость комплексного мониторинга.

Сравнение с данными источников [1-4] показывает, что подобные атаки на SS7 известны с 2017 года и остаются актуальными для сетей GSM и UMTS. Высокая квалификация нарушителя и использование специализированного фреймворка SigPloit подчёркивают, что для защиты недостаточно только прикладных мер – требуется фильтрация на уровне транспортного протокола SCTP.

Практическая значимость работы заключается в отработке навыков:

анализа журналов и трафика;

выявления аномальных запросов АТІ;

настройки межсетевого экрана и iptables для блокировки нежелательного трафика.

Возможные ограничения: сценарий выполняется в виртуальной среде с уровнем сложности 2, что не охватывает все возможные векторы атак на SS7 (например, комбинированные атаки через Diameter или GTP).

#### # Заключение

Цель работы достигнута – освоены методы обнаружения, анализа и устранения последствий компьютерной атаки на примере утечки конфиденциальной информации через уязвимость АТІ в протоколе SS7.

Получены конкретные результаты:

обнаружена эксплуатация уязвимости по логам и трафику;

определены скомпрометированные данные (IMSI, IMEI, MSISDN, местоположение);

закрыта уязвимость на pfSense и с помощью iptables.

Рекомендации по применению:

внедрить постоянный мониторинг сигнального трафика SS7;

ограничить доступ к порту 2906 на межсетевом экране;

использовать фильтрацию SCTP-трафика на границе сети;

проводить регулярные учения по обнаружению атак на телекоммуникационные протоколы.

Направления для дальнейших исследований:

изучение других уязвимостей SS7 (например, SendRoutingInfo, ProvideSubscriberInfo);

разработка автоматизированных систем обнаружения аномалий в сигнальном трафике;

анализ защищённости протоколов Diameter и GTP.

# Список литературы {.unnumbered}

1 Атаки на SS7: вчера для спецслужб, сегодня для всех / Хабр (habr.com).

2 What is SS7 Attack? (techtarget.com).

3 GitHub - SigPloiter/SigPloit: SigPloit: Telecom Signaling Exploitation Framework - SS7, GTP, Diameter & SIP.

4 SS7\_Vulnerability\_2017\_A4.ENG\_.0003.03.pdf (gsma.com).